



中华人民共和国国家标准

GB/T 41578—2022

电动汽车充电系统信息安全 技术要求及试验方法

Technical requirements and test methods for cybersecurity of
electric vehicle charging system

2022-07-11 发布

2023-02-01 实施

国家市场监督管理总局
国家标准化管理委员会 发布

目 次

前言 I

1 范围 1

2 规范性引用文件 1

3 术语和定义 1

4 缩略语 2

5 充电系统信息安全技术要求 3

 5.1 概述 3

 5.2 硬件安全要求 3

 5.3 软件安全要求 3

 5.4 数据安全要求 4

 5.5 通信安全要求 4

6 试验方法 5

 6.1 硬件安全试验方法 5

 6.2 软件安全试验方法 5

 6.3 数据安全试验方法 5

 6.4 通信安全试验方法 6

前 言

本文件按照 GB/T 1.1—2020《标准化工作导则 第 1 部分：标准化文件的结构和起草规则》的规定起草。

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别专利的责任。

本文件由中华人民共和国工业和信息化部提出。

本文件由全国汽车标准化技术委员会(SAC/TC 114)归口。

本文件起草单位：比亚迪汽车工业有限公司、中国汽车技术研究中心有限公司、北京新能源汽车股份有限公司、北京梆梆安全科技有限公司、戴姆勒大中华区投资有限公司、宝马(中国)服务有限公司、大众汽车(中国)投资有限公司、中国软件评测中心(工业和信息化部软件与集成电路促进中心)、北京长安汽车工程技术研究有限责任公司、上海国际汽车城(集团)有限公司、襄阳达安汽车检测中心有限公司、交通运输部科学研究院。

本文件主要起草人：杨冬生、李春、郑香维、贺可勋、王娅蓉、卢佐华、李宝田、武亨、吴胜男、赵闻、朱科屹、王永珠、李霖、高海龙、李成。

电动汽车充电系统信息安全 技术要求及试验方法

1 范围

本文件规定了电动汽车充电系统信息安全技术要求和试验方法。
本文件适用于电动汽车充电系统信息安全技术的设计、开发与试验。

2 规范性引用文件

下列文件中的内容通过文中的规范性引用而构成本文件必不可少的条款。其中，注日期的引用文件，仅该日期对应的版本适用于本文件；不注日期的引用文件，其最新版本（包括所有的修改单）适用于本文件。

- GB/T 5271.8—2001 信息技术 词汇 第8部分：安全
- GB/T 27930 电动汽车非车载传导式充电机与电池管理系统之间的通信协议
- GB/T 29246—2017 信息技术 安全技术 信息安全管理体系 概述和词汇
- GB/T 35273—2020 信息安全技术 个人信息安全规范
- GB/T 37935—2019 信息安全技术 可信计算规范 可信软件基
- GB/T 40861—2021 汽车信息安全通用技术要求

3 术语和定义

GB/T 29246—2017、GB/T 37935—2019、GB T 35273—2020、GB/T 40861—2021 界定的以及下列术语和定义适用于本文件。

3.1

充电系统 charging system

电动汽车车内，用于动力电池充电的相关功能系统。

注1：也称车内充电系统。

注2：根据充电方式及技术架构的不同，充电系统可能包含一个或多个车载控制器[例如电池管理系统(BMS)、车载充电机(OBC)、无线充电系统(WPT)]，或其他集成相关充电功能的车载通信控制单元。

3.2

重要数据 important data

基于充电功能设计及风险评估，被认定为会造成车内充电系统风险的相关数据，包括个人敏感信息和安全重要参数等数据。

3.3

个人敏感信息 personal sensitive information

一旦泄露、非法提供或滥用可能危害人身和财产安全，极易导致个人名誉、身心健康受到损害或歧

视性待遇等的个人信息。

[来源:GB/T 35273—2020,3.2]

3.4

安全重要参数 security important parameter

与安全相关的信息,包含秘密密钥和私钥、口令之类的鉴别数据或其他密码相关参数的信息。

[来源:GB/T 40861—2021,3.13]

3.5

充电系统对外通信 out-of-vehicle communication

充电系统与车辆外部的通信。

注:充电系统对外通信包括传导式充电方式的通信、非传导式充电方式的通信等。

3.6

充电系统对内通信 in-vehicle communication

充电系统各控制器间及其与车辆内电子电气系统间的通信。

注:车内通信包括基于CAN、CAN-FD、LIN、以太网等的车辆内部通信。

3.7

可信根实体 entity of root of trust

用于支撑可信计算平台信任链建立和传递的可对外提供完整性度量、安全存储、密码计算等服务的功能模块。

注:可信根实体包括TPCM、TCM、TPM等。

[来源:GB/T 37935—2019,3.12]

3.8

保密性 confidentiality

信息对未授权的个人、实体或过程不可用或不泄露的特征。

[来源:GB/T 29246—2017,2.12]

3.9

完整性 integrity

准确和完备的特性。

[来源:GB/T 29246—2017,2.40]

3.10

身份鉴别 authentication

身份确认,使数据处理系统能识别出实体的测试实施过程。

[来源:GB/T 5271.8—2001,08.04.12]

4 缩略语

下列缩略语适用于本文件。

BGA:球栅阵列封装(Ball Grid Array)

BMS:电池管理系统(Battery Management System)

CAN:控制器局域网(Controller Area Network)

CAN-FD:灵活数据速率的控制器局域网络(CAN with Flexible Data-rate)

ECU:电子控制单元(Electronic Control Unit)

JTAG:联合测试工作组(Joint Test Action Group)

LGA:平面网格阵列封装(Land Grid Array)

LIN:局域互联网络(Local Interconnect Network)

MCU:微控制单元(Micro Control Unit)

OBC:车载充电机(On-board Charger)

OTP:一次性可编程(One Time Programmable)

SPI:串行外设接口(Serial Peripheral Interface)

TCM:可信密码模块(Trusted Cryptography Module)

TPM:可信平台模块(Trusted Platform Module)

TPCM:可信平台控制模块(Trusted Platform Control Module)

USB:通用串行总线(Universal Serial Bus)

UART:通用异步收发器(Universal Asynchronous Receiver/Transmitter)

WPT:无线电能传输(Wireless Power Transfer)

5 充电系统信息安全技术要求

5.1 概述

充电系统信息安全包括硬件安全、软件安全、数据安全和通信安全四部分。通信安全包括充电系统对外通信安全和充电系统对内通信安全。对于受攻击有可能影响车辆或系统的风险,充电系统中与外部充电装置直接进行通信的控制器需采取信息安全措施。

5.2 硬件安全要求

系统硬件满足以下要求:

- a) 充电系统所使用的关键芯片(例如 MCU、加密芯片、通信芯片等),宜采取必要的保护措施(例如采用 BGA/LGA 等封装的芯片)减少暴露管脚;
- b) 充电系统调试接口应禁用或设置安全访问控制;
- c) 充电系统的直流充电通信网络与车内网络应进行隔离。

5.3 软件安全要求

5.3.1 安全启动

充电系统软件宜具备安全启动的功能,安全启动功能可通过可信根实体进行保护。充电系统的可信根、引导程序(BootLoader 程序)及系统固件应符合以下要求:

- a) 不被篡改;
- b) 若被篡改,充电系统无法正常启动。

5.3.2 安全日志

充电系统宜具有安全日志功能并满足以下要求:

- a) 充电系统有安全事件(例如通信认证失败、安全启动失败等)发生时,对相关信息进行记录;
- b) 充电系统的安全日志中,至少包括触发日志的事件发生时间(绝对时间或相对时间)和事件类型;
- c) 充电系统对安全日志进行安全存储,防止日志在非物理破坏攻击下被损毁及未授权的添加、访问、修改和删除;安全日志可记录存储在充电系统内、其他 ECU 内或云端服务器内。

5.4 数据安全要求

5.4.1 数据完整性

充电系统应保护存储的重要数据的完整性,宜采用完整性校验机制或 OTP 设置等保护方法。

5.4.2 数据保密性

充电系统应保护存储的重要数据的保密性,宜采用软件加密或硬件加密等保护方法。

5.5 通信安全要求

5.5.1 充电系统对外通信安全

5.5.1.1 通信连接安全

有无线充电功能、即插即充功能的充电系统应具有身份鉴别机制。

5.5.1.2 通信传输安全

充电系统对外通信涉及重要数据传输时,应满足以下要求:

- a) 充电系统对重要数据的传输使用密文传输,按照 6.4.1.2 a) 进行试验,保证该传输数据在被截获后无法得到明文数据;
- b) 充电系统对重要数据的传输采用完整性校验机制,按照 6.4.1.2 b) 进行试验,充电系统对完整性校验不通过的重要数据不响应;
- c) 充电系统对重要数据的传输采用防重放机制,按照 6.4.1.2 c) 进行试验,对于重放数据,充电系统能识别到重要数据为非法的重放数据且不响应。

5.5.1.3 通信接口安全

充电系统通信接口安全应满足以下要求:

- a) 通信接口具有通信指令安全性验证机制,按照 6.4.1.3 a) 进行试验,不响应除 GB/T 27930 规定的充电协议和诊断协议及主机厂规定的协议之外的通信指令;
- b) 直流充电通信接口不对充电系统以及车内其他系统进行软件升级和软件标定等;
- c) 通信接口不具有访问车内通信总线数据的功能。

5.5.2 充电系统对内通信安全

充电系统对内通信涉及重要数据传输时,应满足以下要求:

- a) 充电系统传输的重要数据使用密文传输,按照 6.4.2 a) 进行试验,保证该传输数据在被截获后无法得到明文数据;

- b) 充电系统对重要数据的传输采用完整性校验机制,按照 6.4.2 b) 进行试验,充电系统对完整性校验不通过的重要数据不响应;
- c) 充电系统对重要数据的传输采用防重放机制,按照 6.4.2 c) 进行试验,对于重放数据,充电系统能识别到重要数据为非法的重放数据且不响应。

6 试验方法

6.1 硬件安全试验方法

硬件安全试验应按照下列流程依次进行:

- a) 查阅芯片手册分析充电系统关键芯片是否采用必要的措施(例如采用 BGA/LGA 等封装的芯片)减少暴露管脚;
- b) 分析评估是否存在暴露的调试接口(例如 JTAG 接口、USB 接口、UART 接口、SPI 接口等),若存在,评估调试接口是否有鉴权校验机制;
- c) 使用总线工具分别连接直流充电通信网络和车内网络并同时获取其通信数据,检查两者之间的通信数据是否存在差异。

6.2 软件安全试验方法

6.2.1 安全启动

安全启动试验包括可信根防篡改试验、充电系统 Bootloader 程序校验试验、充电系统固件校验试验。安全启动试验应按照下列流程依次进行。

- a) 充电系统可信根防篡改试验:获取充电系统安全启动可信根存储区域的访问方法和地址,使用软件调试工具写入数据,重复多次试验判断是否可将数据写入该存储区域。
- b) 充电系统 Bootloader 程序校验试验:提取充电系统正常运行的 Bootloader 程序,使用软件调试工具修改该 Bootloader 程序的签名信息,将修改后的 Bootloader 程序写入到充电系统的指定区域,监测充电系统是否正常加载 Bootloader 程序及系统固件。
- c) 充电系统固件校验试验:获取充电系统正常运行的系统固件,使用软件调试工具修改系统固件程序的签名信息,将破坏后的系统固件写入到充电系统的指定区域,监测充电系统是否正常工作。

6.2.2 安全日志

安全日志试验应按照下列流程依次进行:

- a) 模拟安全事件发生,从记录日志的系统上读取日志,检查日志记录情况;
- b) 检查日志中是否包含触发日志的事件发生时间、事件类型;
- c) 通过软件调试工具尝试访问、修改或删除已记录的安全日志。

6.3 数据安全试验方法

6.3.1 数据完整性

使用软件调试工具修改充电系统的重要数据,监测重要数据是否被修改;若重要数据被修改,则监

测重要数据被修改后,充电系统是否不使用该重要数据。

6.3.2 数据保密性

使用软件调试工具读取充电系统的重要数据,监测重要数据是否被读取;若重要数据被读取,则监测该重要数据是否为密文存储。

6.4 通信安全试验方法

6.4.1 充电系统对外通信安全

6.4.1.1 通信连接安全

用测试设备模拟充电设备接入到充电系统对外通信网络中,监测充电系统是否只对身份鉴别通过的通信设备启动充电功能。

6.4.1.2 通信传输安全

进行通信传输安全试验时,将测试设备接入充电系统对外通信网络并应按照下列流程依次进行:

- a) 获取传输的数据,检查重要数据是否以密文形式通过网络传输;
- b) 发送被篡改、删除或插入的重要数据,监测充电系统对该重要数据的响应情况;
- c) 获取传输的通信数据,然后重放获取的该通信数据,监测充电系统对该重要数据的识别和响应情况。

6.4.1.3 通信接口安全

通信接口安全试验应按照下列流程依次进行:

- a) 用测试设备模拟充电设备接入充电系统,分别发送正确的样例数据和不正确的样例数据,监测充电系统对样例数据的响应情况;
- b) 获取充电系统控制器软件升级、软件标定样例数据,将测试设备接入直流充电通信接口,发送软件升级和软件标定的样例数据,监测充电系统响应情况;
- c) 将测试设备接入充电系统对外通信网络,测试设备尝试访问车内通信数据,监测车内通信数据获取情况。

6.4.2 充电系统对内通信安全

将测试设备接入充电系统所接车内通信网络,充电系统对内通信安全试验按照下列流程依次进行:

- a) 获取传输的数据,检查重要数据是否以密文形式通过网络传输;
- b) 发送被篡改、删除或插入的重要数据,监测充电系统对该重要数据的响应情况;
- c) 获取传输的通信数据,然后重放获取的通信数据,监测充电系统对该重要数据的识别及响应情况。

中 华 人 民 共 和 国
国 家 标 准
电动汽车充电系统信息安全
技术要求及试验方法
GB/T 41578—2022

*

中国标准出版社出版发行
北京市朝阳区和平里西街甲2号(100029)
北京市西城区三里河北街16号(100045)

网址: www.spc.org.cn

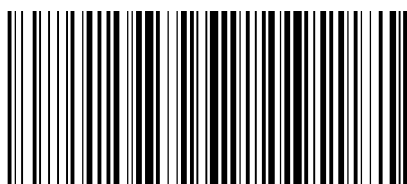
服务热线: 400-168-0010

2022年7月第一版

*

书号: 155066 · 1-70523

版权专有 侵权必究



GB/T 41578—2022



码上扫一扫 正版服务到